UNIT 4 · TOPIC 4.3

Endpoint Hardening Controls

Quiz

Instructions: This quiz has 18 multiple-choice questions, 1 point each. Circle the letter of the single best answer for each question.

Name: **Date:** **Class:**

1. A company wants to reduce device security risk across all departments. Which of the following is best classified as a managerial control for device security?

- ○ A. Configuring antivirus software on all employee laptops
- ○ B. Developing an acceptable use policy for company-owned devices
- ○ C. Enabling automatic screen-lock timeouts on workstations
- ○ D. Installing host-based firewalls on all workstations

2. Which statement best describes how anti-malware software helps protect a device?

- ○ A. It encrypts all files on the device so malware cannot read them
- ○ B. It blocks unauthorized network connections at the network perimeter
- ○ C. It detects and removes malicious programs before or after they execute
- ○ D. It prevents users from installing unapproved software through group policy enforcement

3. What is the primary security reason an organization should apply operating system updates promptly?

- ○ A. Updates add new features that improve user productivity
- ○ B. Updates patch known vulnerabilities that adversaries could actively exploit
- ○ C. Updates reduce the device's overall power consumption
- ○ D. Updates ensure compatibility with the latest peripheral hardware

4. An agricultural-tech company's GPS-guided tractors are running firmware that is 18 months behind the current vendor release. A CVE with a CVSS score of 8.7 has just been published for the outdated firmware version. Which risk-management strategy has the greatest immediate impact on reducing device risk?

- ○ A. Disconnecting all tractors from the internet until a full risk assessment is completed
- ○ B. Applying the available firmware update to address the published CVE
- ○ C. Deploying network-based intrusion detection sensors on the tractor control network
- ○ D. Requiring equipment operators to sign an acceptable use policy before accessing the machinery

5. A company is comparing two endpoint protection strategies: Strategy 1 uses signature-based antivirus updated weekly; Strategy 2 uses behavior-based anti-malware updated daily. Which explanation best accounts for Strategy 2 providing stronger protection against novel malware?

- ○ A. Behavior-based tools are less resource-intensive, so they scan more files per second
- ○ B. Daily definition updates guarantee the signature database is always complete and current
- ○ C. Signature-based tools can only detect threats already in their definition database, whereas behavior-based tools flag suspicious activity patterns regardless of whether the malware has a known signature
- ○ D. Behavior-based tools encrypt endpoint files before malware can access them

6. An audit reveals that employees are connecting personal USB drives to company laptops, creating a potential malware introduction vector. Which combination of controls most effectively addresses this risk by pairing a managerial control with a technical control?

- ○ A. Installing antivirus software and enabling automatic scans on USB insertion
- ○ B. Enabling a host-based firewall and logging all USB connection events
- ○ C. Applying the latest OS patches and delivering phishing awareness training
- ○ D. Creating a removable media policy and configuring device control software to block unauthorized USB devices

7. An organization deploys behavior-based anti-malware, enforces a quarterly patch-management policy, and mandates annual security awareness training. A threat actor successfully exploits a zero-day vulnerability in a productivity application before any patch is available. Which statement best evaluates the effectiveness of the organization's risk-management strategy?

- ○ A. The strategy is ineffective because none of the controls prevented the zero-day attack
- ○ B. The strategy is partially effective; the controls reduce exposure to known threats and residual risk from human error, but zero-day exploitation inherently falls outside the protection scope of patch management and may evade behavior-based detection if the exploit is sufficiently novel
- ○ C. The organization should have implemented a stricter acceptable use policy to prevent zero-day exploitation
- ○ D. The anti-malware software must have been misconfigured, since properly deployed behavior-based tools reliably detect zero-day exploits

8. A risk manager must choose an update policy for internet-connected farm equipment: Policy 1 applies firmware updates automatically upon vendor release; Policy 2 stages updates through a test environment before production deployment. Which analysis most accurately evaluates the security trade-off between these policies?

- ○ A. Both policies carry equivalent risk because firmware updates rarely introduce new vulnerabilities or stability issues
- ○ B. Policy 1 is always preferable because minimizing the vulnerability exposure window is the only security consideration
- ○ C. Policy 2 eliminates vulnerability risk because testing ensures updates contain no exploitable flaws
- ○ D. Policy 1 minimizes the vulnerability window but risks deploying untested changes that could disrupt critical equipment operation; Policy 2 reduces that operational risk but extends the period of known vulnerability exposure, the correct choice depends on the severity of the CVE and the criticality of uninterrupted equipment operation

9. Following reports of cyberattacks against internet-connected agricultural equipment, a security engineer must recommend a prioritized risk-management strategy. The equipment currently runs outdated firmware, lacks anti-malware capability, and has no host-based firewall configured. Referencing the NIST SP 800-53 control framework, which sequence of controls best addresses the highest-risk gaps first?

- ○ A. Conduct a risk assessment and establish a patch-management policy first; then apply firmware updates to remediate known CVEs; then implement host-based firewalls and anti-malware as layered technical controls
- ○ B. Configure host-based firewalls on all devices first, then install anti-malware, then apply firmware updates
- ○ C. Install behavior-based anti-malware on all devices first, as endpoint malware detection is the highest-priority control for IoT equipment
- ○ D. Deliver security awareness training and establish an acceptable use policy before implementing any technical controls, to ensure operator compliance

10. A technician is setting up a host-based firewall on a Windows workstation for the first time. Which action represents the correct first step?

- ○ A. Access the firewall configuration through the operating system's built-in security settings

- ○ B. Download and install a third-party antivirus application
- ○ C. Update the device's network adapter driver to the latest version
- ○ D. Create a new administrator account dedicated to firewall management

11. A technician has just finished installing anti-malware software on a newly imaged workstation. Which step is most important to perform immediately afterward?

- ○ A. Restart the workstation to refresh network adapter settings
- ○ B. Add the anti-malware installation directory to the host-based firewall's outbound allow list
- ○ C. Configure the software to perform a full scan once per week and disable real-time protection to save resources
- ○ D. Update the anti-malware software's virus definition database before running the first scan

12. A device administrator discovers that automatic operating system updates have been disabled on a company laptop. Which action should the administrator take first to implement the correct mitigation?

- ○ A. Uninstall all recently added third-party applications
- ○ B. Run a full antivirus scan to check for existing malware before making any changes
- ○ C. Re-enable automatic updates in the operating system settings
- ○ D. Reset the device to factory settings to remove any unauthorized configuration changes

13. A network administrator needs to configure a host-based firewall on an employee's laptop to allow outbound HTTPS traffic while blocking all unsolicited inbound connections. Which firewall rule set correctly implements this policy?

- ○ A. Block all inbound traffic; allow all outbound traffic on all ports
- ○ B. Allow inbound TCP port 443; block all other inbound; allow outbound TCP port 443; block all other outbound
- ○ C. Allow all inbound traffic on port 443; block all other ports bidirectionally
- ○ D. Block all unsolicited inbound connections; allow outbound TCP port 443; block all other outbound traffic

14. A security team confirms that a critical vulnerability (CVSS 9.1) affects the OS on all company endpoints. The vendor patch is available. Which implementation sequence best follows industry patch-management best practice?

- ○ A. Deploy the patch to all production systems immediately to minimize exposure time
- ○ B. Wait 30 days to observe community feedback on the patch's stability before deploying to any system
- ○ C. Test the patch in a staging environment, document the test results, then deploy to production in prioritized order starting with the highest-risk systems
- ○ D. Apply the patch only to systems that handle sensitive data and monitor all other systems for signs of exploitation

15. An audit at an agricultural-tech company reveals that employees are using personal smartphones to access work email on the corporate network without any Mobile Device Management (MDM) enrollment. Which implementation step should a security engineer take first to mitigate this risk?

- ○ A. Block all smartphone MAC addresses at the perimeter firewall
- ○ B. Deploy an MDM solution and establish a BYOD policy requiring device enrollment before network access is permitted
- ○ C. Configure the email server to reject login requests from mobile device user agents
- ○ D. Issue company-owned smartphones to all employees to replace personal devices

16. A security engineer at an agricultural-tech company has configured host-based firewalls on all internet-connected tractors, blocking all inbound connections and restricting outbound traffic to the vendor's update

servers and the company control platform only. Two weeks after deployment, one tractor loses connectivity to the GPS navigation service. Which action best reflects correct mitigation implementation and change-logging practice aligned with NIST CM and AU control families?

- ○ A. Revert all firewall rules to their pre-implementation defaults to restore connectivity and document the reversion
- ○ B. Disable the host-based firewall on the affected tractor and continue monitoring for further incidents
- ○ C. Review the firewall rule logs to confirm the GPS service traffic is being blocked; add a specific allow rule for the GPS service's destination IP range and port; document the rule change with the business justification; and update the security baseline accordingly
- ○ D. Issue a standing policy waiver exempting all GPS-connected tractors from the firewall policy and record the waiver approval in the risk register

17. A CISO must implement a layered endpoint protection plan for 500 workstations under three operational constraints: (1) budget for only one EDR solution, (2) staff capacity for only two patch cycles per month, and (3) a legacy application incompatible with the latest OS version on 40 workstations. Which implementation plan best balances security, operational constraints, and correct residual-risk logging?

- ○ A. Deploy EDR only on the 460 systems running the latest OS and leave the 40 legacy hosts without endpoint protection
- ○ B. Deploy EDR on all 500 systems; apply OS patches to all systems except the 40 legacy hosts on the two monthly cycles; document the unpatched legacy systems as a risk exception with compensating controls (EDR coverage and network segmentation) recorded in a Plan of Action and Milestones (POA&M)
- ○ C. Apply OS patches to all 500 systems immediately, including the 40 legacy hosts, accepting that the legacy application may break in production
- ○ D. Postpone all EDR deployment until all 500 systems can be upgraded to the latest OS version

18. After completing a risk assessment, a security engineer at an agricultural-tech firm implements a device hardening plan for internet-connected machinery: (1) firmware patched quarterly, (2) behavior-based anti-malware deployed, (3) host-based firewalls configured to allow only vendor update and control-platform traffic outbound, and (4) a device security policy established. Which evaluation most accurately identifies the plan's completeness gaps relative to NIST SP 800-53 implementation and logging requirements?

- ○ A. The plan is complete; it addresses patching, malware protection, firewall configuration, and policy, all four device-security control categories
- ○ B. The plan is largely sound but has implementation gaps: quarterly patching is insufficient for high-severity CVEs requiring emergency response; no logging or monitoring procedure is defined for firewall events or anti-malware detections; no change-control process for firewall rule updates is specified, these gaps should be documented as residual risks in a POA&M with target remediation milestones
- ○ C. The plan is adequate because the physical operating environment of agricultural machinery reduces the urgency of continuous logging and monitoring
- ○ D. Behavior-based anti-malware makes firmware patching redundant since behavioral detection intercepts exploitation attempts before they can succeed